

Architettura scalabile di video analytics per la grande distribuzione

RetailSight - piattaforma AI end-to-end per riduzione delle perdite, analisi dei flussi e conformità espositiva

Simone La Porta

Master AI Solutions Architect - ProfessionAI

Caso guida: analisi video su 180 punti vendita, edge-cloud hybrid

Indice

1. Executive summary	3
2. Nota metodologica	4
3. Contesto e caso d'uso	4
3.1 Profilo di RetailSight	4
3.2 Casi d'uso e scenari operativi	4
3.3 Dimensionamento di riferimento	5
4. Requisiti	6
4.1 Requisiti funzionali	6
4.2 Requisiti non funzionali	7
4.3 Vincoli normativi	7
5. Pattern architetturali	8
5.1 Decisione 1: edge-first per l'inferenza video	9
5.2 Decisione 2: backbone a eventi con percorsi separati	9
5.3 Decisione 3: vendor-neutral con tecnologie candidate	9
6. Architettura di alto livello	10
6.1 Mappa delle tecnologie candidate	11
7. Specifica dei componenti	12
7.1 Componenti edge (per store)	12
7.2 Componenti cloud - piattaforma dati	13
7.3 Componenti cloud - servizi applicativi e ML	14
7.4 Copertura dei requisiti	15
8. Flussi dati e ciclo di vita del dato	16
9. Ciclo di vita dei modelli	19
9.1 I gate di governance	20
9.2 Rollout, rollback, retraining	20
10. Politiche di AI responsabile	20
10.1 Privacy by design	20
10.2 Equità e gestione del bias	21
10.3 Trasparenza e spiegabilità	21
10.4 Posizionamento rispetto all'EU AI Act	21
11. Sicurezza e governance	22
11.1 Modello delle minacce e controlli	22
11.2 Ruoli e responsabilità	22
11.3 Governance del dato e gestione degli incidenti	23
12. Piano di monitoraggio e KPI	23
13. Valutazione del rischio e mitigazioni	25
14. Piano di ottimizzazione dei costi	26
15. Roadmap e milestone	28
16. Conclusioni e lettura critica	29

17. Appendici	29
17.1 Glossario	29
17.2 Riferimenti normativi e framework	30
17.3 Checklist di accettazione	30
17.4 Nota sui diagrammi	31

1. Executive summary

RetailSight gestisce una catena di 180 supermercati e dispone già, in ogni punto vendita, di un impianto di telecamere nato per la sicurezza fisica. Il progetto definisce l'architettura di una piattaforma AI end-to-end che trasforma quell'infrastruttura passiva in una fonte di dati operativi per quattro casi d'uso: riduzione di furti e perdite (shrinkage), analisi dei flussi di clientela e delle code, conformità delle esposizioni promozionali (planogram adherence) e insight per merchandising e layout.

La decisione architetturale che orienta tutto il resto è dove far vivere il video. Centralizzare gli stream di 7.000 e più telecamere verso il cloud è insostenibile per banda e costi, e indifendibile sul piano privacy. L'architettura è quindi edge-first: ogni store ospita un nodo di inferenza che analizza il video sul posto, applica l'anonimizzazione e pubblica verso il cloud solo eventi strutturati e brevi clip selezionate, una frazione stimata nell'1-3% del girato. Il cloud concentra ciò che beneficia della scala: storage governato, analisi batch, training e gestione del ciclo di vita dei modelli, dashboard e integrazioni. Un backbone a eventi separa il percorso caldo degli alert (sotto i 2 secondi end-to-end) dal percorso freddo dell'analisi storica.

Il documento è una specifica progettuale, non un'implementazione: definisce requisiti, pattern e componenti con responsabilità e SLA, flussi dati con politiche di retention, ciclo di vita dei modelli con gate di governance, politiche di AI responsabile, piano di monitoraggio, rischi e mitigazioni, piano dei costi e roadmap di adozione in tre ondate. Le scelte tecnologiche restano volutamente vendor-neutral, con una mappa di tecnologie candidate per componente.

Obiettivo	Beneficio atteso	Metrica di successo
Riduzione shrinkage	Meno perdite economiche da furti e non conformità	Riduzione % shrinkage vs baseline di reparto
Efficienza operativa	Personale allocato su code e flussi reali	Tempo medio di coda; ore/staff riallocate
Decisioni data-driven	Layout e promo guidati da traffico e conversione	Adozione insight (azioni/mese); uplift promo
Reattività operativa	Alert in tempo reale con revisione umana	Latenza alert p95 < 2 s; precision >= 0,85 a regime
Riusabilità della piattaforma	Base per futuri casi d'uso AI	Tempo di onboarding di un nuovo caso d'uso

Tabella 1.1 - Obiettivi, benefici e metriche di successo.

Stakeholder principali: direzione loss prevention (sponsor), operations di store, merchandising, IT/piattaforme, DPO e funzione legale, sicurezza informatica, rappresentanze del personale. Gli ultimi tre non sono destinatari passivi ma parte del processo di governance: su un sistema di videoanalisi in ambienti aperti al pubblico la conformità è un requisito architetturale, non un adempimento a valle.

2. Nota metodologica

Natura del documento e dei dati

Questo è uno studio di progettazione a scopo didattico. RetailSight è un'azienda fittizia; i volumi (store, telecamere, banda, eventi) sono ipotesi di dimensionamento dichiarate nel capitolo 3 e servono a rendere concrete le scelte, non a descrivere un impianto reale. Nessun dato personale è coinvolto. I pattern del capitolo 5 seguono l'impostazione della traccia: linee guida concettuali, non prescrizioni implementative; le tecnologie citate nel capitolo 6 sono candidate di riferimento, non scelte di prodotto. Ogni decisione non banale è accompagnata dalla motivazione e dalle alternative scartate; le sezioni di lettura critica segnalano limiti e punti deboli anziché nasconderli.

Perimetro. Sono inclusi: requisiti funzionali e non funzionali con vincoli normativi; scelta e combinazione dei pattern architetturali; architettura di alto livello e topologia di deployment; specifica dei componenti con SLA; flussi dati e ciclo di vita del dato; ciclo di vita dei modelli con gate di governance; politiche di AI responsabile; sicurezza e governance; monitoraggio e KPI; rischi; costi; roadmap. Sono esclusi: la selezione di prodotti specifici, il dimensionamento puntuale dell'hardware, il piano di progetto esecutivo e l'implementazione del software applicativo.

3. Contesto e caso d'uso

3.1 Profilo di RetailSight

RetailSight opera 180 punti vendita tra supermercati di prossimità e superstore, con un impianto TVCC esistente di 30-60 telecamere IP per store, oggi usato solo per la sicurezza fisica e la gestione assicurativa. La rete degli store è eterogenea: la connettività varia dalla fibra dei superstore urbani a link più modesti nei punti vendita minori. Questo vincolo infrastrutturale non è un dettaglio: qualunque architettura che presupponga l'upload continuo del video verso un data center fallisce prima sul contratto di banda che sul software.

3.2 Casi d'uso e scenari operativi

Caso d'uso	Domanda di business	Output del sistema	Utente
Shrinkage	Dove e quando si concentrano furti e perdite?	Alert real-time su eventi sospetti; heatmap dei reparti a rischio	Loss prevention, staff di store
Flussi e code	Quanto personale serve, dove e in che fascia oraria?	Conteggi, tempi di coda, previsioni di affluenza	Store manager, operations
Planogram adherence	Le esposizioni promo sono conformi agli accordi?	Report di conformità per campagna e store, con evidenze	Merchandising, trade marketing

Caso d'uso	Domanda di business	Output del sistema	Utente
Insight layout	Come si muovono i clienti e dove si converte?	Percorsi aggregati, dwell time, conversione per zona	Merchandising, category manager

Tabella 3.1 - I quattro casi d'uso della piattaforma.

Tre scenari rendono concreto il funzionamento atteso. Primo: nel reparto liquori una persona rimuove più articoli in rapida sequenza occultandoli; il nodo edge classifica il comportamento come evento sospetto, il motore regole verifica soglia e zona, lo staff riceve sull'app una notifica con clip di 15 secondi e decide come intervenire; l'esito (vero o falso allarme) rientra nel sistema come dato di qualità del modello. Secondo: alle 17:40 le code superano la soglia dei quattro clienti per cassa; lo store manager riceve la segnalazione e apre una cassa; a fine mese l'analisi batch mostra la ricorrenza del picco e corregge la pianificazione dei turni. Terzo: il lunedì di avvio di una campagna, il giro di ispezione batch confronta le testate promozionali con il planogram di riferimento e segnala al merchandising gli store non conformi, con foto a supporto.

In tutti e tre gli scenari la decisione resta a una persona: il sistema segnala, documenta e misura, non agisce mai in autonomia su un cliente o su un dipendente. Questa non è prudenza generica ma un vincolo di design, ripreso nei capitoli 10 e 11.

3.3 Dimensionamento di riferimento

Grandezza	Valore assunto	Nota
Punti vendita	180	rollout completo, ondata 3
Telecamere per store	30-60 (media 40)	~7.200 totali
Risoluzione / frame rate di analisi	1080p, 10-15 fps	sottocampionati dal flusso nativo
Eventi per store al giorno	200-500	tutti i casi d'uso
Clip per evento	10-20 s	solo eventi sopra soglia
Uplink medio per store	2-6 Mbit/s	eventi + clip; il video resta locale
Latenza alert critici	< 2 s end-to-end	budget per tratta in Figura 8.2
Disponibilità	99,9% cloud critico; 99,5% edge	il singolo store degrada, non ferma la catena

Tabella 3.2 - Ipotesi di dimensionamento dichiarate.

Lettura critica. Il numero più fragile della tabella è l'uplink medio: dipende dall'ipotesi che eventi e clip pesino l'1-3% del girato, che a sua volta dipende dalle soglie del motore regole e dalla qualità dei

modelli. Se i falsi positivi raddoppiano, raddoppia anche il traffico, e con i link più deboli il margine si assottiglia. Per questo la validazione della stima è uno dei criteri del gate di fine pilota (capitolo 15), non un assunto da verificare a rollout avvenuto.

4. Requisiti

4.1 Requisiti funzionali

ID	Requisito	Caso d'uso
RF-01	Ingestion degli stream dalle telecamere IP on-premises e selezione delle porzioni video da conservare	tutti
RF-02	Preprocessing e anonimizzazione (blur volti) prima di qualunque persistenza o trasferimento fuori dallo store	tutti
RF-03	Inferenza real-time: rilevamento oggetti, tracking, riconoscimento di eventi (comportamenti sospetti, congestione)	shrinkage, code
RF-04	Inferenza batch: heatmap, percorsi aggregati, conformità planogram, trend storici	planogram, insight
RF-05	Gestione e versioning dei modelli: training, validazione, rollout canary, rollback, ritiro	tutti
RF-06	Configurazione delle business rules: soglie di alert, zone di interesse, orari, per store e per reparto	tutti
RF-07	Dashboard e reportistica aggregata per BI	code, insight, planogram
RF-08	Alerting verso lo staff con presa in carico, esito e integrazione con i sistemi operativi (POS, incident)	shrinkage, code
RF-09	Metriche operative e ML: performance, deriva, falsi positivi, con storicizzazione	tutti
RF-10	Gestione di annotazione e dataset: etichettatura, qualità, versioning dei set di training	tutti

Tabella 4.1 - Requisiti funzionali.

4.2 Requisiti non funzionali

ID	Requisito	Target
RNF-01	Scalabilità orizzontale su store e telecamere	180 store senza redesign; +1 store = provisioning, non progetto

ID	Requisito	Target
RNF-02	Latenza del percorso real-time	p95 < 2 s end-to-end per alert critici
RNF-03	Disponibilità e resilienza	99,9% servizi cloud critici; 99,5% edge; degrado locale isolato
RNF-04	Tracciabilità e audit	lineage dato-modello-decisione ricostruibile; audit log append-only
RNF-05	Controllo dei costi	costo per store/mese tracciato; nessun componente senza owner di costo
RNF-06	Conformità privacy	GDPR, provvedimenti Garante, art. 4 Statuto dei lavoratori; AI Act
RNF-07	Sicurezza	cifratura in transito e a riposo; mTLS tra edge e cloud; RBAC
RNF-08	Operabilità	aggiornamento remoto dei nodi edge; nessun intervento on-site ordinario

Tabella 4.2 - Requisiti non funzionali.

4.3 Vincoli normativi

Il quadro normativo non è un allegato: definisce lo spazio delle architetture ammissibili. Quattro fonti pesano più delle altre.

- **GDPR.** La videoanalisi in aree aperte al pubblico è sorveglianza sistematica su larga scala: la DPIA ex art. 35 è obbligatoria prima del pilota. Base giuridica da costruire sul legittimo interesse con balancing test documentato; minimizzazione e retention brevi come impostazione di default, non come eccezione.
- **Linee guida EDPB 3/2019 e provvedimento Garante sulla videosorveglianza.** informativa a doppio livello (cartellonistica e informativa estesa), proporzionalità delle finalità, limiti stringenti alla conservazione delle immagini: la retention di riferimento resta nell'ordine delle 72 ore, superabile solo per eventi specifici documentati.
- **Art. 4 dello Statuto dei lavoratori.** le telecamere riprendono inevitabilmente anche il personale: l'impiego richiede accordo sindacale o autorizzazione dell'Ispettorato del lavoro, e vieta l'uso dei dati per il controllo della prestazione. Nessuna metrica della piattaforma può essere riferita a un singolo dipendente.
- **EU AI Act (Reg. 2024/1689).** il design evita per costruzione le pratiche vietate dall'art. 5: nessuna identificazione biometrica, nessun riconoscimento delle emozioni, nessuna categorizzazione biometrica. Il posizionamento e le sue conseguenze sono analizzati nel capitolo 10.

Lettura critica. Requisiti e vincoli tirano in direzioni opposte in un punto preciso: la retention breve imposta dalla normativa riduce il materiale disponibile per addestrare e migliorare i modelli. La risoluzione adottata è conservare a lungo termine solo ciò che non è più riferibile a persone (feature,

aggregati) e trattare i clip di training come dataset separato, con base giuridica e ciclo di vita propri (capitolo 9). È un compromesso che costa qualcosa in velocità di iterazione dei modelli e compra la sostenibilità legale dell'intero impianto.

5. Pattern architetturali

La traccia elenca sei pattern come linee guida concettuali. Qui vengono combinati in tre decisioni di impianto, ciascuna motivata contro le alternative realistiche.

Pattern	Problema che risolve in RetailSight	Dove si applica
Layered	separare acquisizione, elaborazione, orchestrazione e interfacce; evolvibilità per livello	architettura logica (Figura 6.1)
Edge-cloud hybrid	latenza, banda e privacy del video; scala per store	topologia di deployment (Figura 6.2)
Event-driven / stream	alert in tempo reale; disaccoppiamento produttori-consumatori	bus eventi, percorso caldo (Figura 8.2)
Modularità dei servizi	componenti sostituibili con contratti espliciti; niente monolite AI	specifica componenti (capitolo 7)
CQRS concettuale	il carico di scrittura (eventi) non deve contendere con le letture BI	piattaforma dati (capitolo 8)
Separation of concerns	sicurezza, governance e telemetria come responsabilità trasversali esplicite	capitoli 10-12

Tabella 5.1 - I sei pattern della traccia e il loro impiego.

5.1 Decisione 1: edge-first per l'inferenza video

L'alternativa cloud-only è stata valutata e scartata con un conto diretto. Uno stream 1080p utile all'analisi pesa 2-4 Mbit/s: per lo store medio da 40 telecamere significa 80-160 Mbit/s di upload continuo, fuori scala per i link dei punti vendita minori e comunque un costo ricorrente ingiustificato, dato che oltre il 95% dei frame non contiene eventi di interesse. A questo si sommano la latenza di andata e ritorno, incompatibile con il budget dei 2 secondi nei momenti di congestione della rete, e l'aggravio privacy di centralizzare video non anonimizzato di clienti e dipendenti. L'alternativa opposta, edge-only, eliminerebbe i costi cloud ma rinunciarebbe a ciò che rende la piattaforma un asset: analisi cross-store, training centralizzato, governance unica dei modelli. La scelta ibrida assegna a ciascun ambiente ciò che sa fare meglio: all'edge l'inferenza a bassa latenza e l'anonimizzazione alla fonte, al cloud la scala, lo storico e il controllo.

Lettura critica. Il prezzo dell'edge-first è una flotta di 180 nodi hardware da gestire: aggiornamenti, guasti, sicurezza fisica, capacity planning per store. È un costo operativo reale che l'architettura

mitiga ma non azzerà (gestione flotta remota, RNF-08); la valutazione economica del capitolo 14 lo tratta come capex ammortizzato e lo confronta con l'opex cloud evitato.

5.2 Decisione 2: backbone a eventi con percorsi separati

Il percorso caldo (evento -> regole -> alert) e quello freddo (persistenza -> batch -> BI) condividono la stessa sorgente ma hanno requisiti opposti: il primo ottimizza la latenza, il secondo il throughput e il costo per terabyte. Un bus eventi con consumer indipendenti disaccoppia i due mondi e rende ogni nuovo caso d'uso un consumer aggiuntivo, non una modifica alla pipeline esistente. La separazione CQRS si applica in senso concettuale: il write path degli eventi non è mai interrogato direttamente dalla BI, che legge da proiezioni e aggregati dedicati. L'alternativa scartata è l'integrazione punto-punto tra inferenza e applicazioni: più semplice al giorno uno, ingestibile al caso d'uso numero tre.

La semantica di consegna scelta è at-least-once con de-duplicazione a valle tramite chiave idempotente dell'evento: la perdita silenziosa di un alert di sicurezza è più costosa di un duplicato filtrato dal motore regole.

5.3 Decisione 3: vendor-neutral con tecnologie candidate

La traccia chiede pattern non prescrittivi; la piattaforma è quindi specificata per contratti tra componenti, con una mappa di tecnologie candidate (Tabella 6.1) al posto di una distinta di prodotti. La scelta ha una motivazione anche strategica: il lock-in sui servizi di video analytics gestiti dei cloud provider è tra i più costosi da sciogliere, perché lega i modelli, il formato degli eventi e la fatturazione allo stesso fornitore. Restano due punti fermi non negoziabili qualunque sia il vendor: residenza dei dati in regione UE e formati aperti per eventi e dataset (capitolo 8).

Lettura critica. La neutralità ha un costo di integrazione: ciò che un servizio gestito offre pronto va assemblato. Per una catena da 180 store il conto torna comunque a favore della neutralità, ma per il pilota da 5 store un servizio gestito sarebbe più rapido; la roadmap accetta esplicitamente questo trade-off per non costruire il pilota su fondamenta da smontare.

6. Architettura di alto livello

Due viste complementari: i livelli funzionali (cosa fa la piattaforma) e la topologia edge-cloud (dove lo fa). Le ipotesi grafiche comuni a tutte le figure sono raccolte nell'appendice 17.4.

Architettura logica RetailSight

Livelli funzionali e responsabilità trasversali; la topologia di deployment è nella figura successiva



Figura 6.1 - Architettura logica a livelli con responsabilità trasversali. Legenda: barra colorata a sinistra dei box = livello di appartenenza; frecce = flusso principale dal basso verso l'alto.

Il livello di acquisizione normalizza le sorgenti: stream RTSP dalle telecamere, transazioni POS, conteggi dai varchi. Il preprocessing con anonimizzazione sta volutamente in questo livello, prima di qualunque persistenza: nessun componente a valle vede volti in chiaro. La piattaforma dati disaccoppia produttori e consumatori con il bus eventi, che trasporta senza conservare, e mantiene due depositi distinti per natura del dato: il lakehouse per eventi persistiti e feature, l'object storage per le clip cifrate. I servizi AI separano l'inferenza online (edge) da quella batch (cloud) e concentrano training e registry in un unico punto di governo. I servizi applicativi traducono gli eventi in decisioni operative tramite regole configurabili (RF-06), e il livello di presentazione espone dashboard, console di revisione e API di integrazione. Le tre responsabilità trasversali (sicurezza, osservabilità, governance) attraversano tutti i livelli e hanno capitoli dedicati.

Topologia di deployment edge-cloud

Il video resta nello store; verso il cloud viaggiano eventi e clip selezionate

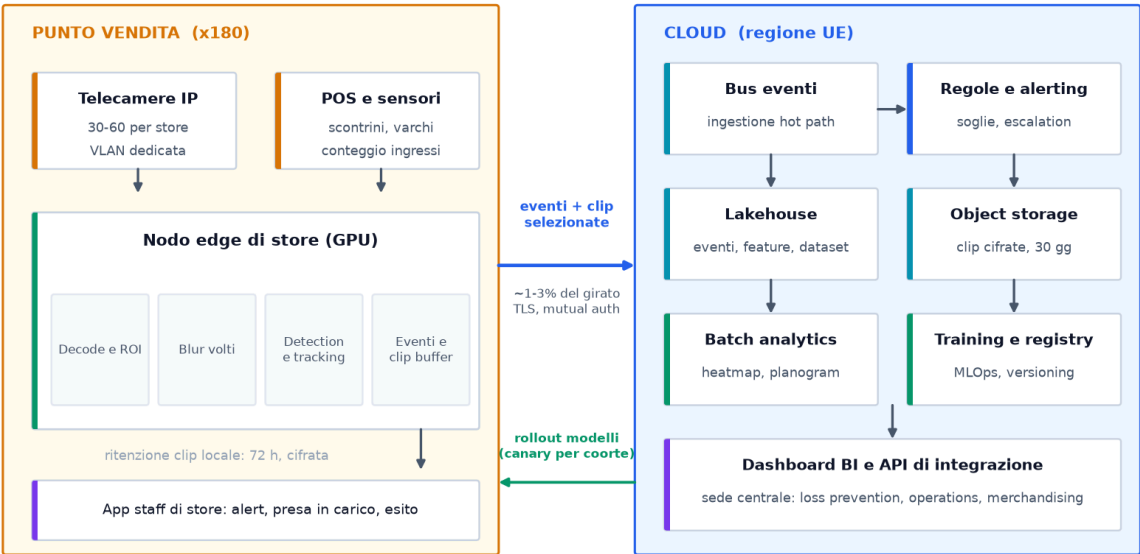


Figura 6.2 - Topologia di deployment edge-cloud. Legenda: cornice ambra = perimetro fisico dello store, replicato per 180; cornice blu = regione cloud UE; freccia blu = percorso dati verso il cloud; freccia verde = distribuzione dei modelli verso l'edge.

Il flusso end-to-end si legge sulla figura: (1) le telecamere alimentano il nodo edge su VLAN dedicata; (2) il nodo decodifica, applica le zone di interesse, anonimizza e inferisce; (3) gli eventi strutturati e le clip sopra soglia salgono al cloud su canale cifrato; (4) il percorso caldo attiva regole e notifiche mentre quello freddo alimenta lakehouse e storage; (5) batch analytics e training consumano lo storico; (6) i modelli certificati tornano all'edge con rollout canary per coorti di store. Il buffer locale di 72 ore copre i distacchi di rete: lo store degradato continua a rilevare e notificare localmente, e riallinea il cloud al ritorno della connettività (store-and-forward).

6.1 Mappa delle tecnologie candidate

Per ogni componente la tabella indica le tecnologie candidate e il criterio con cui scegliere, mantenendo l'impianto vendor-neutral. Nessuna riga è una prescrizione: è lo spazio di scelta entro cui il pilota deve decidere, misurando.

Componente logico	Tecnologie candidate	Criterio di scelta
Acquisizione video	RTSP/ONVIF, GStreamer, DeepStream	compatibilità con il parco TVCC esistente
Runtime inferenza edge	ONNX Runtime, TensorRT, OpenVINO	throughput per watt sull'hardware scelto
Modelli detection/tracking	famiglia YOLO, RT-DETR; ByteTrack	precision/recall su dataset interno, licenza d'uso

Componente logico	Tecnologie candidate	Criterio di scelta
Bus eventi	Kafka, Kinesis, Pub/Sub; MQTT sul tratto edge	throughput, ordering per store, costo a regime
Object storage clip	S3-compatibile (anche MinIO)	cifratura, lifecycle policy, costo per TB
Lakehouse	Parquet + Delta Lake o Iceberg	formati aperti, time travel per audit
Orchestrazione batch	Airflow, Dagster	osservabilità dei run, backfill
Gestione flotta edge	Kubernetes + KubeEdge, fleet manager IoT	aggiornamenti OTA, stato desiderato dichiarativo
Registry e MLOps	MLflow; registry del cloud provider	lineage modello-dataset, approvazioni, API di rollout
Serving batch cloud	Triton, KServe	GPU sharing, autoscaling a zero
Osservabilità	OpenTelemetry, Prometheus, Grafana; Evidently per drift	correlazione telemetria operativa e ML
Identità e accessi	OIDC (Keycloak o IdP aziendale), OPA per policy	integrazione con l'IdP esistente, policy as code

Tabella 6.1 - Tecnologie candidate per componente.

Perché nessun prodotto è nominato come scelta

La traccia chiede pattern concettuali e la piattaforma è pensata per sopravvivere ai fornitori: i contratti tra componenti (formato eventi, API del registry, layout del lakehouse) sono la parte stabile; i prodotti sono la parte sostituibile. Il pilota seleziona una combinazione concreta e la roadmap ne verifica i costi reali prima della scala.

7. Specifica dei componenti

Ogni componente è specificato per responsabilità, contratto di input/output, SLA atteso e requisiti di sicurezza e privacy. I componenti sono raggruppati per dominio di deployment.

7.1 Componenti edge (per store)

Componente	Responsabilità	Input -> Output	SLA	Sicurezza e privacy
Video ingestion	connessione agli stream, decodifica, sottocampionamento, health check telecamere	RTSP -> frame normalizzati	riconnessione < 30 s	VLAN dedicata; nessuna persistenza del flusso

Componente	Responsabilità	Input -> Output	SLA	Sicurezza e privacy
Preprocessing e anonimizzazione	ROI, resize, blur volti certificato prima di ogni uscita dal nodo	frame -> frame anonimizzati	in linea con il frame rate	il blur non è disattivabile da configurazione remota
Inferenza online	detection, tracking, classificazione eventi con modello versionato	frame -> eventi candidati	p95 < 150 ms/frame	modello firmato; solo metadati in uscita
Event builder e clip buffer	arricchimento eventi (store, zona, telecamera), estrazione clip, retention locale 72 h	eventi candidati -> eventi + clip	publish < 100 ms	clip cifrate at rest; chiavi per store
Agente di flotta	aggiornamenti OTA di modelli e runtime, telemetria del nodo, stato desiderato	manifest firmato -> nodo aggiornato	rollout coerente < 24 h	verifica firma; rollback automatico su health fail

Tabella 7.1 - Componenti edge.

7.2 Componenti cloud - piattaforma dati

Componente	Responsabilità	Input -> Output	SLA	Sicurezza e privacy
Gateway di ingestione	terminazione mTLS, autenticazione dei nodi, rate limiting, validazione schema eventi	eventi edge -> bus	99,9%; p95 < 50 ms	certificati per nodo; schema registry
Bus eventi	trasporto pub/sub, ordering per store, replay	eventi -> consumer	99,9%; retention 7 gg	ACL per topic; cifratura in transito
Lakehouse	persistenza di eventi, feature e aggregati in formato aperto, partizionati per store/data	eventi -> tabelle governate	batch SLA orario	row-level access per ruolo; niente PII
Object storage clip	conservazione clip cifrate con lifecycle (30 gg, poi cancellazione automatica)	clip -> archivio a scadenza	99,9%	accesso tracciato caso per caso; legal hold su evento aperto

Componente	Responsabilità	Input -> Output	SLA	Sicurezza e privacy
Catalogo e lineage	schema, ownership, classificazione, lineage dato-feature-modello	metadati -> catalogo interrogabile	aggiornamento giornaliero	fonte di verità per gli audit

Tabella 7.2 - Componenti della piattaforma dati.

7.3 Componenti cloud - servizi applicativi e ML

Componente	Responsabilità	Input -> Output	SLA	Sicurezza e privacy
Motore regole	valutazione soglie/zone/orari per store, de-duplicazione, arricchimento di contesto	eventi -> alert qualificati	p95 < 200 ms	configurazioni versionate con approvazione
Servizio alerting	consegna notifiche, presa in carico, escalation, registrazione esiti	alert -> notifiche + esiti	p95 < 1 s	l'esito umano è tracciato per l'audit e il retraining
Orchestrazione workflow	scheduling delle pipeline batch (ingest -> trasformazione -> inferenza -> report), retry, gestione errori, backfill	DAG -> run tracciati	run notturno completato entro le 6:00	esecuzione con identità di servizio dedicate
Batch analytics	heatmap, percorsi, code, planogram sui dati del lakehouse	tabelle -> aggregati e report	run notturno < 4 h	solo dati non identificanti
Training e registry	pipeline di training riproducibili, versioning modelli-dataset, gate di promozione	dataset -> modelli certificati	retraining < 1 settimana	approvazione a due persone per la promozione
Dashboard e API	BI self-service, console di revisione, API verso POS/CRM/incident	aggregati -> viste e integrazioni	99,9%	RBAC; le API espongono solo aggregati

Tabella 7.3 - Servizi applicativi e ML.

7.4 Copertura dei requisiti

Componente	Domini o	RF-01	RF-02	RF-03	RF-04	RF-05	RF-06	RF-07	RF-08	RF-09	RF-10
Video ingestione	edge	X									
Preprocessing e anonimizzazione	edge		X								
Inferenza online	edge			X							
Event builder / clip	edge	X		X							
Agente di flotta	edge					X					
Gateway + bus	cloud	X							X		
Lakehouse + storage	cloud	X			X						X
Motor e regole	cloud						X		X		
Alerting	cloud								X	X	
Orchestrazione	cloud				X	X					
Batch analytics	cloud				X			X			
Training e registry	cloud					X				X	X

Componente	Domino	RF-01	RF-02	RF-03	RF-04	RF-05	RF-06	RF-07	RF-08	RF-09	RF-10
Dashb oard e API	cloud						X	X			

Tabella 7.4 - Matrice componenti / requisiti funzionali.

Lettura critica. La matrice serve a scovare due patologie: requisiti orfani e componenti tuttofare. Gli accorpamenti (gateway con bus, lakehouse con storage) sono voluti; catalogo e lineage non compaiono perché coprono il requisito trasversale RNF-04, non un requisito funzionale. Qui ogni requisito ha almeno un owner e nessun componente copre più di tre requisiti; il candidato monolite era l'inferenza online, che nelle prime bozze inglobava anche regole e clip. Separare il motore regole dall'inferenza costa un salto di rete in più sul percorso caldo, ma permette di cambiare soglie senza toccare i modelli: nel retail le soglie cambiano ogni settimana, i modelli ogni trimestre.

8. Flussi dati e ciclo di vita del dato

Ciclo di vita del dato

Dalla ripresa alla cancellazione: a ogni passaggio il dato diventa meno identificante



Figura 8.1 - Ciclo di vita del dato con finestre di retention e classificazione. Legenda: chip sotto ogni fase = retention; etichetta sopra = classe del dato.

Il principio ordinatore è la de-identificazione progressiva: a ogni passaggio il dato perde capacità di riferirsi a una persona e guadagna durata di conservazione. Lo stream live esiste solo in memoria sul nodo edge. La selezione trattiene i soli segmenti con eventi e il blur è applicato prima di ogni persistenza. Le clip, cifrate, vivono 72 ore sull'edge e 30 giorni nel cloud se associate a un evento; oltre, solo su evento aperto documentato (legal hold). Feature e derivati (traiettorie, conteggi) non contengono frame e durano 12 mesi per alimentare modelli e stagionalità; gli aggregati BI, anonimi per costruzione, 24 mesi per i confronti anno su anno. La cancellazione a fine retention è automatica e lascia traccia nell'audit log.

Dato	Dove	Retention	Classe	Accesso
Stream live	edge (RAM)	minuti	personale	nessuno diretto
Clip evento	edge	72 h	personale (blur)	loss prevention, su caso
Clip evento	cloud	30 gg (o legal hold)	pseudonimo	loss prevention + audit trail
Eventi strutturati	lakehouse	12 mesi	pseudonimo	team dati, per ruolo
Feature e traiettorie	lakehouse	12 mesi	non identificante	team dati, ML
Aggregati BI	lakehouse	24 mesi	anonimo	business, self-service
Dataset di training	area governata	per versione modello	pseudonimo	ML, sotto gate G1

Tabella 8.1 - Politiche di retention e accesso per classe di dato.

Il contratto dati del sistema è l'evento strutturato. Un esempio rende l'idea del livello di dettaglio (e di ciò che volutamente non c'è: nessun dato biometrico, nessun identificativo di persona).

```
{
  "event_id": "st042-cam17-20260719-000183",
  "schema_version": "1.2",
  "store_id": "st042",
  "camera_id": "cam17",
  "zone": "liquori-corsia-3",
  "type": "suspect_behavior",
  "confidence": 0.87,
  "model": {"name": "behavior-cls", "version": "2.4.1"},
  "ts_start": "2026-07-19T17:41:03Z",
  "ts_end": "2026-07-19T17:41:18Z",
  "clip_ref": "s3://retailsight-clips/st042/2026/07/19/000183.enc",
  "track_summary": {"objects": 1, "dwell_s": 15, "items_removed_est": 4}
}
```

Estratto 8.1 - Payload di un evento (campione illustrativo).

Percorso real-time di alerting

Budget di latenza per tratta; obiettivo end-to-end sotto i 2 secondi

end-to-end < 2 s

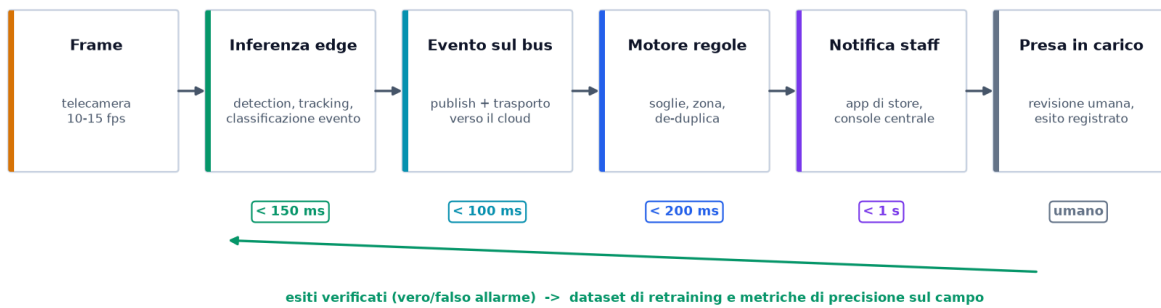


Figura 8.2 - Percorso real-time con budget di latenza per tratta. Legenda: chip sotto ogni passo = budget; freccia verde = ritorno degli esiti verso il retraining.

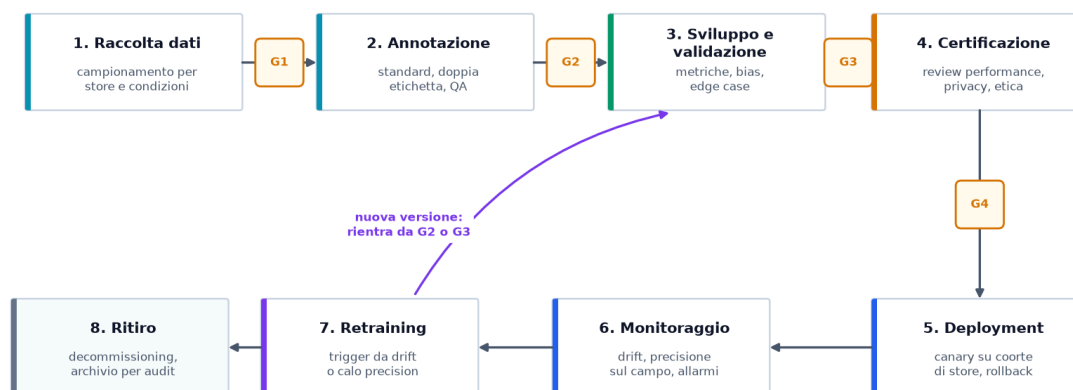
Il budget end-to-end di 2 secondi è ripartito per tratta con margine: la somma dei budget è circa 1,5 secondi e lascia mezzo secondo di riserva per i picchi. Le scelte di robustezza del percorso caldo: consegna at-least-once con de-duplica idempotente nel motore regole; backpressure sul bus con priorità agli eventi di sicurezza; store-and-forward sull'edge nei distacchi di rete, con notifica locale allo staff come degrado controllato. Il percorso di lettura (dashboard, report) è fisicamente separato da quello di scrittura: le query BI leggono proiezioni aggiornate a intervalli, mai il bus o le tabelle di ingestione (CQRS concettuale).

Lettura critica. L'anello di feedback della Figura 8.2 è il meccanismo più importante e il più fragile: la qualità delle metriche di precision sul campo dipende dalla disciplina con cui lo staff registra gli esiti. Se la registrazione è percepita come burocrazia, i dati si sporcano e il retraining eredita il rumore. Il design lo mitiga riducendo l'esito a due tocchi sull'app, ma il rischio comportamentale resta e va presidiato in formazione e incentivi, non solo in architettura.

9. Ciclo di vita dei modelli

Ciclo di vita dei modelli

Otto fasi, quattro gate di governance; nessun avanzamento senza evidenze



G1 liceità e privacy del dataset - G2 qualità etichette (accordo tra annotatori $\geq 95\%$) - G3 soglie di metriche e fairness superate - G4 approvazione del comitato di governance

Figura 9.1 - Ciclo di vita dei modelli con gate di governance. Legenda: riquadri ambra = gate; la freccia viola riporta le nuove versioni dentro il percorso di validazione.

Ogni fase ha un responsabile, criteri di successo misurabili ed evidenze che devono esistere perché il gate successivo si apra. La tabella è il contratto operativo del ciclo di vita; i gate G1-G4 sono descritti sotto.

Fase	Responsabile	Criteri di successo	Evidenze richieste
1. Raccolta dati	data engineer + DPO	campione rappresentativo per store, orari, stagioni	scheda dataset; base giuridica; esito G1
2. Annotazione	ML engineer + annotatori	accordo tra annotatori $\geq 95\%$ sul campione di controllo	linee guida versionate; report qualità; esito G2
3. Sviluppo e validazione	ML engineer	soglie di metriche raggiunte su test set indipendente; analisi per sottogruppi e edge case	model card; report metriche e fairness; esito G3
4. Certificazione	comitato governance AI	review di performance, privacy, sicurezza, etica	verbale di approvazione; esito G4
5. Deployment	MLOps	canary su coorte senza regressioni per 2 settimane	piano di rollout e rollback; metriche canary
6. Monitoraggio	MLOps + loss prevention	drift e precision sul campo entro soglia	dashboard ML; log allarmi drift

Fase	Responsabile	Criteri di successo	Evidenze richieste
7. Retraining	ML engineer	miglioramento misurato sulla metrica che ha fatto scattare il trigger	confronto vecchio/nuovo su stesso test set
8. Ritiro	MLOps + governance	nessun consumer attivo; artefatti archiviati	registro di decommissioning per audit

Tabella 9.1 - Fasi, responsabilità, criteri ed evidenze.

9.1 I gate di governance

- **G1 - Liceità del dataset.** verifica DPO su base giuridica, minimizzazione e provenienza dei dati di training; blocca l'uso di dati raccolti fuori policy.
- **G2 - Qualità delle etichette.** sotto il 95% di accordo il dataset torna in annotazione: un modello addestrato su etichette incoerenti sposta il problema a valle, dove costa di più.
- **G3 - Metriche e fairness.** soglie per caso d'uso (capitolo 12) e analisi disaggregata per condizioni di ripresa e zone; il capitolo 10 definisce l'approccio in assenza di attributi protetti.
- **G4 - Approvazione di governance.** il comitato valuta ciò che le metriche non vedono: function creep, impatti su clienti e personale, coerenza con la DPIA. Approvazione a verbale, revocabile.

9.2 Rollout, rollback, retraining

Il rollout è canary per coorti: 5 store rappresentativi per due settimane, confronto con il resto della flotta su precision, falsi positivi e latenza, poi estensione progressiva. Il rollback è automatico su violazione delle soglie di health e manuale su decisione del monitoraggio: la versione precedente resta installata sul nodo, il ripristino è un cambio di puntamento, non un nuovo deploy. I trigger di retraining sono tre: drift statistico sulle distribuzioni di input (stagionalità, refit dei negozi), calo della precision sul campo oltre 5 punti percentuali, cambiamento strutturale dichiarato (nuovo formato store, nuove categorie merceologiche). Ogni nuova versione rientra dal gate G2 o G3 a seconda che il retraining abbia toccato i dati o solo il modello.

Lettura critica. Il rischio dei gate è la burocrazia: quattro cancelli possono trasformare un fix da due giorni in un ciclo da sei settimane. La mitigazione è di processo: G1 e G2 si ripetono solo se il dataset cambia, e per i retraining ordinari G4 opera in silenzio-assenso con diritto di veto entro cinque giorni lavorativi. La versione pesante del processo si riserva ai cambi di architettura del modello o di finalità d'uso, dove il rischio lo giustifica.

10. Politiche di AI responsabile

10.1 Privacy by design

Le scelte di privacy non sono policy sovrapposte all'architettura: sono l'architettura. Il video non lascia lo store; l'anonimizzazione avviene sul nodo edge prima di ogni persistenza e non è

disattivabile da configurazione remota; il sistema non esegue riconoscimento facciale, identificazione o re-identificazione di persone, né costruisce profili individuali: gli oggetti tracciati sono anonimi e il tracking vive solo nella finestra dell'evento. Le metriche aggregate non sono mai riconducibili a un singolo dipendente (vincolo art. 4 Statuto, capitolo 4.3). La DPIA precede il pilota e si aggiorna a ogni estensione di finalità.

10.2 Equità e gestione del bias

Il rischio concreto è un sistema che genera alert di sospetto in modo sistematicamente sbilanciato, per condizioni di ripresa (zone buie, angoli di camera), per caratteristiche dell'abbigliamento o per correlazioni spurie apprese dai dati. La difficoltà è che gli attributi protetti non sono disponibili, né sarebbe lecito raccogliarli: la fairness si presidia quindi per proxy. In validazione (gate G3): performance disaggregate per store, zona, fascia oraria e condizioni di illuminazione, con soglia massima di divergenza tra sottogruppi. In esercizio: monitoraggio della distribuzione degli alert per zona e store contro le baseline, con indagine obbligatoria sugli scostamenti anomali. A valle: la revisione umana su ogni alert e il campionamento periodico dei falsi positivi da parte del comitato, per intercettare pattern che le metriche aggregate non mostrano.

10.3 Trasparenza e spiegabilità

La spiegabilità richiesta qui è operativa, non accademica: chi riceve un alert deve capire perché è scattato e con quali evidenze. Ogni alert espone il tipo di evento, la regola e le soglie che lo hanno qualificato, la confidenza del modello e la clip a supporto; ogni decisione è ricostruibile a posteriori con la catena dato-modello-regola-esito (lineage, capitolo 11). Verso il pubblico: informativa a doppio livello negli store; verso il personale: informazione e confronto con le rappresentanze previsti dalla procedura ex art. 4.

10.4 Posizionamento rispetto all'EU AI Act

Il sistema è progettato per restare fuori dalle pratiche vietate dall'art. 5: nessuna identificazione biometrica remota, nessun riconoscimento delle emozioni, nessuna categorizzazione biometrica, nessun social scoring. Non ricade negli usi ad alto rischio dell'allegato III nella configurazione descritta: non identifica persone, non prende decisioni su individui, non valuta il personale. Restano gli obblighi di trasparenza e le buone pratiche di un sistema con impatto su persone: il ciclo di vita del capitolo 9 adotta di fatto la disciplina dei sistemi ad alto rischio (gestione del rischio, data governance, sorveglianza umana, logging) come standard interno, allineandosi a ISO/IEC 42001 e al NIST AI RMF.

Lettura critica. Questa classificazione è stabile solo finché lo è il perimetro funzionale. Basta una richiesta apparentemente innocua, riconoscere i recidivi, contare i dipendenti alle casse, e il sistema attraversa il confine: biometria, alto rischio, e un impianto di conformità da ricostruire. Il function creep è il rischio regolatorio numero uno di questa piattaforma, ed è il motivo per cui ogni estensione di finalità passa dal gate G4 e da un aggiornamento della DPIA, senza eccezioni. L'architettura aiuta (niente feature biometriche nei dati persistiti significa che certe derive sono tecnicamente impossibili senza rifare la piattaforma), ma la tenuta è di governance prima che tecnica.

11. Sicurezza e governance

11.1 Modello delle minacce e controlli

La superficie d'attacco ha quattro fronti principali. I nodi edge: hardware fisicamente accessibile in 180 sedi, con dati personali a bordo; controlli: disco cifrato, secure boot, attestazione del nodo, chiavi per store così che la compromissione di un nodo non esponga la flotta. Il canale edge-cloud: mTLS con certificati per nodo, rotazione automatica, rate limiting sul gateway. La supply chain dei modelli: un modello è codice eseguibile a tutti gli effetti; solo artefatti firmati dal registry vengono accettati dall'agente di flotta, e la promozione richiede due approvazioni. Le interfacce applicative: RBAC su dashboard e API, accesso alle clip tracciato caso per caso con motivazione, sessioni e query BI limitate ad aggregati.

Ambito	Controllo	Nota di design
Dati in transito	TLS ovunque; mTLS edge-cloud	nessun canale in chiaro, nemmeno intra-store
Dati a riposo	cifratura lato storage; chiavi gestite centralmente, separate per store	raggio di esplosione limitato
Identità	OIDC su IdP aziendale; service account per componente	nessuna credenziale condivisa
Autorizzazione	RBAC per ruolo; policy as code (OPA)	le policy sono versionate e testabili
Audit	log append-only per accessi a clip, modifiche a regole, promozioni di modelli	supporta DPIA, ispezioni, incidenti
Rete store	VLAN telecamere isolata; il nodo edge è l'unico punto di uscita	una telecamera compromessa non parla col cloud

Tabella 11.1 - Controlli di sicurezza per ambito.

11.2 Ruoli e responsabilità

Ruolo	Responsabilità principali
Sponsor (loss prevention)	priorità dei casi d'uso, budget, accettazione dei KPI
Platform architect	coerenza dell'architettura, contratti tra componenti, scelte tecnologiche
ML engineer	modelli, dataset, metriche; fasi 1-3 e 7 del ciclo di vita
MLOps / piattaforma	flotta edge, pipeline, rollout, monitoraggio operativo e ML
DPO	DPIA, basi giuridiche, retention, gate G1, rapporti con il Garante

Ruolo	Responsabilità principali
Security officer	modello delle minacce, controlli, incident response, audit di sicurezza
Comitato governance AI	gate G4, estensioni di finalità, campionamento dei falsi positivi, verbali
Store operations	gestione alert, registrazione esiti, feedback dal campo

Tabella 11.2 - Matrice delle responsabilità.

11.3 Governance del dato e gestione degli incidenti

La governance del dato si appoggia a tre strumenti già definiti: il catalogo con classificazione e ownership (capitolo 7), le politiche di retention per classe (capitolo 8) e il lineage dato-feature-modello-decisione che rende ogni alert ricostruibile. Per gli incidenti valgono due runbook distinti: incidente di sicurezza (compromissione nodo, accesso anomalo alle clip) con isolamento del nodo, revoca certificati, analisi forense e valutazione di notifica ex art. 33 GDPR; incidente di qualità AI (ondata di falsi positivi, drift improvviso) con declassamento degli alert a revisione preventiva, eventuale rollback del modello e post-mortem al comitato. Entrambi hanno severità, tempi di presa in carico e catena di escalation definiti nel piano operativo.

12. Piano di monitoraggio e KPI

Il monitoraggio corre su due piani che condividono la stessa infrastruttura di telemetria ma rispondono a domande diverse: il piano operativo (il sistema funziona?) e il piano ML (il sistema decide bene?). Tenerli nello stesso stack di osservabilità permette di correlarli: un calo di precision che coincide con il guasto di una coorte di telecamere è un problema di manutenzione, non di modello.

KPI	Definizione	Criterio di accettazione	Frequenza
Precision alert critici	alert confermati / alert emessi, su esiti registrati	$\geq 0,85$ a regime ($\geq 0,75$ nel pilota)	settimanale
Recall eventi critici	eventi rilevati / eventi accaduti, stimata su campioni di audit	$\geq 0,70$	mensile
Tasso falsi positivi	quota di alert smentiti dalla revisione	$\leq 15\%$; nessuno store $> 25\%$ per 2 settimane	settimanale
Latenza end-to-end	frame -> notifica, percentile 95	< 2 s	continua
Throughput inferenza	inferenze/ora per nodo e per flotta	entro il dimensionamento per store	continua

KPI	Definizione	Criterio di accettazione	Frequenza
Disponibilità	uptime servizi critici cloud / nodi edge	99,9% / 99,5%	mensile
MTTA / MTTR incidenti	presa in carico / risoluzione	MTTA < 15 min per sev-1; MTTR < 4 h	mensile
Drift dei modelli	divergenza distribuzioni input e output vs baseline di training	indagine oltre soglia; retraining se persistente	giornaliera
Frequenza retraining	cicli completati / trigger scattati	100% dei trigger gestiti entro 2 settimane	trimestrale
Costo per inferenza / storage	costo cloud allocato per unità	trend non crescente per store a parità di carico	mensile

Tabella 12.1 - KPI, criteri di accettazione e frequenze.

Le soglie di allerta operative derivano dai criteri: violazioni di latenza o disponibilità aprono incidenti automatici; violazioni di precision o drift aprono ticket verso il ciclo di vita dei modelli (trigger del capitolo 9.2). La reportistica segue tre cadenze: dashboard continua per operations e MLOps, report settimanale per loss prevention, review mensile con il comitato su fairness, falsi positivi e stato dei rischi.

Lettura critica. Recall è il KPI metodologicamente più debole: gli eventi non rilevati non lasciano traccia nel sistema. La stima su campioni di audit (revisione a campione di finestre video da parte di loss prevention) è costosa e parziale, ma l'alternativa, dichiarare solo la precision, produrrebbe un sistema che sembra migliorare semplicemente diventando più silenzioso. Meglio un numero imperfetto e dichiarato di un angolo cieco.

13. Valutazione del rischio e mitigazioni

Matrice dei rischi

Posizione inerente (pieno) e residua dopo mitigazione (vuoto)

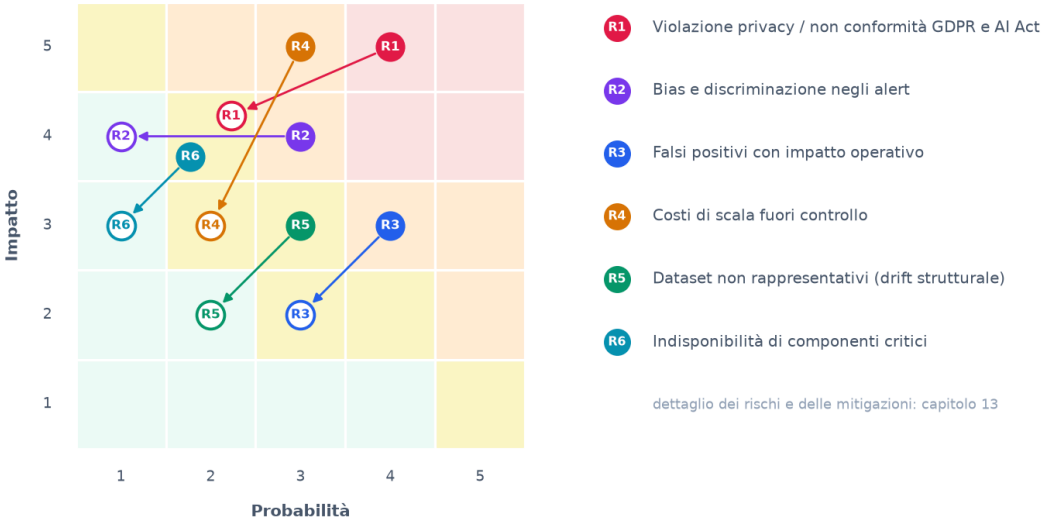


Figura 13.1 - Matrice dei rischi: posizione inerente (pieno) e residua post-mitigazione (vuoto). Scala 1-5 per probabilità e impatto.

ID	Rischio	Mitigazioni principali	Owner
R1	Violazione privacy / non conformità (GDPR, art. 4, AI Act)	anonimizzazione alla fonte; retention brevi; DPIA; gate G1/G4; audit; procedura art. 4 prima del pilota	DPO
R2	Bias e discriminazione negli alert	validazione disaggregata (G3); monitoraggio distribuzione alert; revisione umana; campionamento del comitato	comitato AI
R3	Falsi positivi con impatto operativo	soglie per store; de-duplica; revisione a due tocchi; feedback loop verso retraining; KPI dedicato	loss prevention
R4	Costi di scala fuori controllo	edge-first (banda); tiering e retention; unit economics per store; gate go/no-go a fine ondata	platform architect
R5	Dataset non rappresentativi	campionamento per store/stagione (G1); drift monitoring; retraining su trigger	ML engineer
R6	Indisponibilità di componenti critici	degrado locale isolato; store-and-forward; ridondanza dei servizi cloud critici; runbook	MLOps

Tabella 13.1 - Registro dei rischi con mitigazioni e ownership.

La lettura della matrice riflette una scelta: i rischi di conformità (R1) e di costo (R4) partono più alti perché il loro impatto colpisce l'intero programma, non un singolo store. Le mitigazioni li riportano in area gestibile ma nessun rischio scende a livello trascurabile: su un sistema di videoanalisi in esercizio continuo la pretesa di rischio zero sarebbe essa stessa un segnale di analisi superficiale.

Lettura critica. Il rischio operativamente più insidioso non è il più grave in matrice: è R3. Un sistema che grida al lupo dieci volte al giorno viene spento dallo staff in due settimane, e con esso muore il feedback loop che dovrebbe migliorarlo: R3 non mitigato trasforma un problema di qualità in un fallimento di adozione. È il motivo per cui la soglia sul tasso di falsi positivi è un criterio di accettazione del pilota, con la stessa dignità della precision.

14. Piano di ottimizzazione dei costi

Il piano non stima importi assoluti, che dipenderebbero da prezzi di fornitori qui volutamente non scelti: definisce i driver di costo, il loro comportamento alla scala e le leve progettate per controllarli. La disciplina FinOps entra a regime nell'ondata 3, ma la strumentazione (tagging delle risorse per store e componente, showback mensile) nasce con il pilota: un costo non attribuito è un costo che nessuno ottimizza.

Driver di costo	Comportamento a scala	Leva di controllo
Hardware edge (capex)	lineare con gli store; scalino sul formato (super vs superstore)	dimensionamento per formato; ammortamento 4-5 anni; refresh scaglionato
Banda store-cloud	lineare con eventi e clip, non con le telecamere	soglie del motore regole; compressione clip; qualità dei modelli (meno falsi positivi = meno banda)
Storage cloud	cresce con retention e casi d'uso	lifecycle automatico per classe (Tabella 8.1); tiering a freddo per gli aggregati storici
Compute batch e training	a gradini, legato a retraining e nuovi casi d'uso	scheduling notturno; istanze spot/preemptible; autoscaling a zero del serving batch
Percorso caldo (bus, regole)	lineare con gli eventi	de-duplica alla fonte; priorità per classe di evento
Operazioni flotta	sublineare se automatizzate, lineare se no	aggiornamenti OTA; zero interventi on-site ordinari (RNF-08)

Tabella 14.1 - Driver di costo e leve di controllo.

Le metriche FinOps di riferimento sono tre, tutte già nel piano di monitoraggio: costo totale per store al mese (l'unità economica del business), costo per inferenza (l'efficienza tecnica) e costo per alert utile (l'efficienza del sistema nel suo scopo: unisce costi e qualità, perché scende sia riducendo la

spesa sia riducendo i falsi positivi). Il confronto strutturale resta quello del capitolo 5: il capex dei nodi edge compra l'azzeramento dell'opex di banda e di inferenza cloud continua, ed è la ragione per cui il costo marginale del 181-esimo store si riduce quasi al solo nodo edge e al suo esercizio: le voci che in un'architettura centralizzata crescono con ogni telecamera, trasporto e inferenza cloud del video, qui restano piatte.

Lettura critica. Il punto debole del piano è la stima del capex edge prima di aver scelto l'hardware: la forbice tra un nodo minimo e uno sovradimensionato, moltiplicata per 180, sposta il business case. La roadmap la chiude presto e con dati: il gate di fine pilota richiede il consumo misurato per telecamera e per modello, e il gate di fine ondata 2 verifica il costo per store sulla scala dei 50 prima di impegnare i restanti 130.

15. Roadmap e milestone

Roadmap di adozione

Tre ondate in dodici mesi; ogni ondata termina con un gate go/no-go

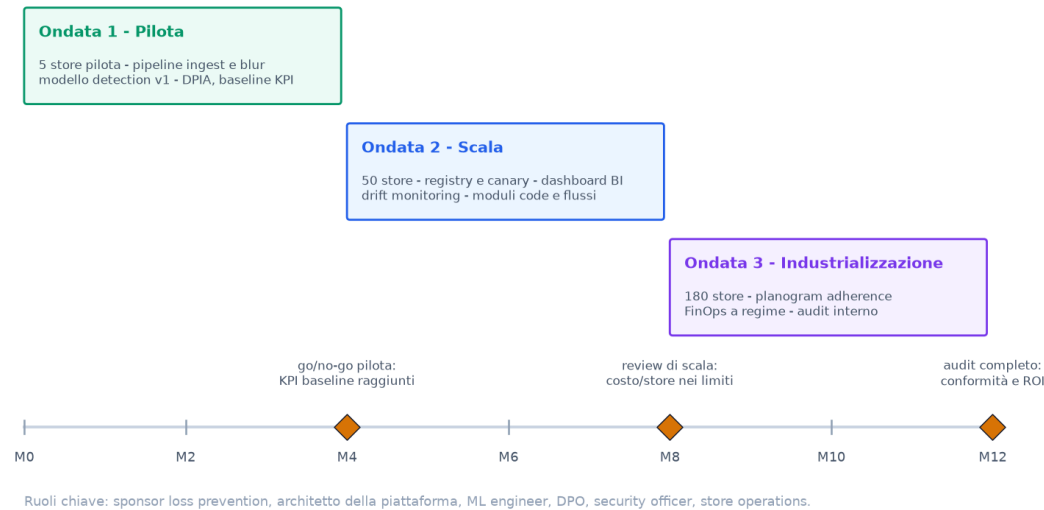


Figura 15.1 - Roadmap in tre ondate su dodici mesi, con gate go/no-go sui rombi. Le durate sono indicative e subordinate agli esiti dei gate.

Ondata	Durata	Deliverable principali	Gate di uscita
1 - Pilota (5 store)	M0-M4	DPIA e procedura art. 4 completate; pipeline ingest + anonimizzazione; modello detection v1; app alert; baseline KPI	KPI pilota raggiunti (precision $\geq 0,75$; latenza < 2 s); stima banda 1-3% validata; costo per telecamera misurato
2 - Scala (50 store)	M4-M8	registry con gate G1-G4 operativi; rollout canary; dashboard BI; drift monitoring; moduli code e flussi	costo per store entro budget; falsi positivi $\leq 15\%$; operazioni flotta senza interventi on-site

Ondata	Durata	Deliverable principali	Gate di uscita
3 - Industrializzazione (180 store)	M8-M12	planogram adherence; FinOps a regime; audit interno di sicurezza e conformità; handover a esercizio	audit superato; ROI misurato vs baseline shrinkage; piattaforma pronta per nuovi casi d'uso

Tabella 15.1 - Ondate, deliverable e criteri di gate.

Tre scelte di sequenza meritano la motivazione. La conformità precede la tecnologia: DPIA e procedura sindacale sono deliverable dell'ondata 1, perché un pilota partito senza basi legali è un debito che nessun refactoring ripaga. Lo shrinkage apre, il planogram chiude: il primo ha il payback più rapido e le regole più semplici, il secondo richiede dataset di riferimento per campagna che maturano solo con la piattaforma in esercizio. I moduli di governance (registry, gate) arrivano con l'ondata 2, non con la 3: farli dopo la scala significherebbe governare retroattivamente una flotta già eterogenea. Il quarto caso d'uso, gli insight di layout, non ha un'ondata dedicata: riusa traiettorie e heatmap del modulo flussi dell'ondata 2 e diventa utile man mano che lo storico si accumula, senza componenti aggiuntivi.

16. Conclusioni e lettura critica

L'architettura proposta risolve il problema posto dalla traccia con tre mosse che si tengono: l'edge-first rende sostenibili banda, latenza e privacy insieme; il backbone a eventi con percorsi separati fa convivere l>alert sotto i 2 secondi con l'analisi storica; il ciclo di vita gated dei modelli e la de-identificazione progressiva del dato rendono il sistema difendibile davanti a un auditor oltre che funzionante. La piattaforma è riusabile per costruzione: un nuovo caso d'uso è un nuovo consumer di eventi e un nuovo modello nel registry, non un nuovo progetto.

I limiti vanno dichiarati con la stessa nettezza. Primo: le ipotesi di dimensionamento (1-3% del girato, 200-500 eventi/store) sono stime progettuali che il pilota deve validare; il capitolo 3 segnala già la sensibilità della banda ai falsi positivi. Secondo: la fairness per proxy del capitolo 10 è il meglio ottenibile senza attributi protetti, ma resta un presidio indiretto: può rilevare distorsioni di zona e condizione, non certificare l'assenza di discriminazione. Terzo: il business case dipende dal capex edge non ancora prezzato e dalla disciplina operativa degli store nel registrare gli esiti; entrambi sono presidiati dai gate, nessuno dei due è eliminabile a tavolino. Quarto: il planogram adherence è specificato a livello di architettura ma il suo modello (confronto esposizione-riferimento) è il meno maturo dei quattro casi d'uso e potrebbe richiedere più iterazioni di quanto la roadmap conceda.

Sviluppi successivi naturali, in ordine di valore: previsione di affluenza a breve termine sui dati di flusso (il dataset si accumula da solo); integrazione con il replenishment per correlare rotture di stock ed esposizioni; estensione del motore regole a eventi compositi multi-camera. Nessuno dei tre richiede modifiche strutturali alla piattaforma.

17. Appendici

17.1 Glossario

Termine	Definizione
Shrinkage	differenza tra stock contabile e fisico: furti, errori, danni
Planogram	schema di riferimento della disposizione prodotti a scaffale
Zona di interesse (ROI)	area del campo visivo su cui l'analisi è attiva
Edge node	server di store che esegue inferenza e anonimizzazione in locale
Percorso caldo / freddo	flusso real-time degli alert / flusso batch di analisi storica
CQRS	separazione tra percorso di scrittura e di lettura dei dati
Canary	rilascio graduale a una coorte limitata prima dell'estensione
Drift	scostamento delle distribuzioni dei dati rispetto al training
DPIA	valutazione d'impatto sulla protezione dei dati (art. 35 GDPR)
Lineage	catena ricostruibile dato -> feature -> modello -> decisione
Store-and-forward	buffering locale con riallineamento al ritorno della connettività
Legal hold	sospensione della cancellazione per un procedimento in corso

Tabella 17.1 - Glossario dei termini usati nel documento.

17.2 Riferimenti normativi e framework

- Reg. (UE) 2016/679 (GDPR), in particolare artt. 5, 6, 13, 25, 33, 35.
- Linee guida EDPB 3/2019 sul trattamento di dati personali attraverso dispositivi video.
- Provvedimento del Garante in materia di videosorveglianza (8 aprile 2010) e FAQ successive.
- L. 300/1970, art. 4 (Statuto dei lavoratori), come modificato dal d.lgs. 151/2015.
- Reg. (UE) 2024/1689 (AI Act), in particolare artt. 5 e 50 e allegato III.
- ISO/IEC 42001:2023 (AI management system); NIST AI Risk Management Framework 1.0.
- ISO/IEC 27001:2022 per il sistema di gestione della sicurezza delle informazioni.

17.3 Checklist di accettazione

ID	Criterio	Riferimento
CA-01	DPIA approvata e procedura art. 4 completata prima dell'accensione del pilota	cap. 4.3, 10.1

ID	Criterio	Riferimento
CA-02	Blur volti verificato su campione prima di ogni trasferimento fuori store	cap. 7.1
CA-03	Latenza p95 < 2 s misurata sul percorso reale	cap. 8, 12
CA-04	Precision $\geq 0,75$ (pilota) / $0,85$ (regime); falsi positivi $\leq 15\%$	cap. 12
CA-05	Gate G1-G4 operativi con evidenze archiviate	cap. 9
CA-06	Retention automatiche attive e verificate per ogni classe di dato	cap. 8
CA-07	Rollback di un modello eseguito con successo in esercizio (test controllato)	cap. 9.2
CA-08	Audit log append-only interrogabile per clip, regole e modelli	cap. 11
CA-09	Showback dei costi per store attivo dal pilota	cap. 14
CA-10	Stima banda eventi+clip validata sul campo (1-3%)	cap. 3.3, 15

Tabella 17.2 - Checklist di accettazione del progetto.

17.4 Nota sui diagrammi

Le sette figure sono generate programmaticamente (matplotlib) da uno script versionato insieme al progetto, per garantire coerenza visiva e riproducibilità. Convenzioni comuni: barra colorata a sinistra di un box = famiglia funzionale del componente; cornici colorate = perimetri di deployment; chip bordati = valori di budget o retention; rombi ambra = gate decisionali. Le ipotesi quantitative mostrate nelle figure (retention, budget di latenza, volumi) sono quelle dichiarate nella Tabella 3.2 e nel capitolo 8.

Sorgenti dei diagrammi: [repository del corso, cartella diagrams/](#)